

Active Directory (AD) is a directory service developed by Microsoft that helps organizations manage users, computers, printers, and other network resources from one central location. It is mainly used in Windows-based environments to make administration easier and improve security.

Instead of creating separate user accounts on every computer, an administrator can create and manage all accounts from Active Directory. It also allows users to log in once and access the resources they are authorized to use.

Some important components of Active Directory include:

- **Domain:** A group of computers and users that share the same database and security policies.
- **Domain Controller (DC):** A server that stores the Active Directory database and authenticates users.
- **Organizational Unit (OU):** Used to organize users, computers, and groups for easier management.
- **Group Policy:** Allows administrators to apply security settings and policies to multiple computers and users at once.

Why is Active Directory important?

- Centralized user and device management.
- Simplifies authentication and authorization.
- Improves network security.
- Makes it easier to enforce security policies.
- Supports single sign-on (SSO), allowing users to access multiple resources with one login.

2. Research Common Active Directory Attacks

Since Active Directory stores important user accounts and permissions, it is often a target for cyber attackers. Some of the most common attacks are:

1. Pass-the-Hash (PtH)

In this attack, the attacker steals the password hash from a compromised computer and uses it to authenticate without knowing the actual password.

Impact:

- Unauthorized access to systems.

- Lateral movement across the network.

2. Kerberoasting

Kerberoasting targets service accounts in Active Directory. The attacker requests service tickets and attempts to crack the encrypted passwords offline.

Impact:

- Service account compromise.
- Privilege escalation.

3. Pass-the-Ticket (PtT)

Instead of stealing password hashes, the attacker steals Kerberos tickets and reuses them to access other systems.

Impact:

- Unauthorized authentication.
- Network compromise.

4. Golden Ticket Attack

This attack occurs when an attacker gains access to the **KRBTGT** account hash. They can create fake Kerberos tickets that allow unrestricted access to the domain.

Impact:

- Full domain compromise.
- Persistent administrator access.

5. DCSync Attack

The attacker pretends to be a Domain Controller and requests password hashes from the real Domain Controller.

Impact:

- Theft of administrator credentials.
- Complete control over the Active Directory environment.

How can organizations protect Active Directory?

- Use strong and unique passwords.
- Enable Multi-Factor Authentication (MFA).
- Limit administrative privileges.
- Regularly update and patch systems.
- Monitor suspicious login activities.
- Use privileged access management (PAM).
- Disable unnecessary accounts and services.

3. Analyze a Privilege Escalation Scenario

Scenario

A company employee receives a phishing email that contains a malicious attachment. After opening the attachment, malware is installed on the employee's computer.

The attacker initially gains access with the employee's standard user account. Since this account has limited permissions, the attacker begins searching for ways to increase their privileges.

During the investigation, the attacker finds that an IT administrator recently logged into the same computer. Cached administrator credentials are still stored in memory.

Using a credential dumping tool, the attacker steals the administrator's credentials and successfully logs in with administrative privileges.

With administrator access, the attacker disables security software, creates a new administrator account, and moves across the network to access sensitive company servers.

Attack Stages

Stage	Description
Initial Access	User opens a phishing email attachment.
Execution	Malware runs on the victim's computer.
Credential Access	Administrator credentials are stolen from memory.

Privilege Escalation The attacker gains administrator privileges.

Lateral Movement The attacker accesses other computers on the network.

Impact Sensitive data may be stolen or systems may be compromised.

How could this attack have been prevented?

Several security measures could have reduced the risk of this attack:

- Train employees to recognize phishing emails.
- Enable Multi-Factor Authentication (MFA).
- Apply the principle of least privilege so users only have the access they need.
- Prevent administrators from logging into regular user workstations whenever possible.
- Use Endpoint Detection and Response (EDR) tools to detect suspicious activity.
- Keep operating systems and applications updated with the latest security patches.
- Monitor login events and unusual privilege changes using SIEM solutions.